

CISSP Printable Practice Exam 29 - Domain 5 - Identity and Access Management (IAM)

Practice Exam 04 - Domain 5

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-079)

Scenario: A transportation authority detects low-rate sign-in attempts against hundreds of employee accounts. Each account receives only a few failures, so the current fixed lockout threshold is not reached. Lowering the threshold would let an attacker lock out large portions of the workforce.

Which response BEST addresses the attack while preserving availability?

- A. Remove all failed-sign-in limits so legitimate users cannot be locked out
- B. Apply the same permanent lockout after one failure to every employee account
- C. Use adaptive throttling and detection across accounts, sources, and authentication patterns
- D. Increase the password expiration frequency without changing failure monitoring

Question 2 (CISSP4-080)

Scenario: A customer may remain signed in to an investment portal for routine portfolio viewing. Changing the destination bank account for withdrawals creates substantially greater risk than ordinary viewing activity.

What should the portal require immediately before accepting the bank-account change?

- A. Fresh authentication appropriate to the transaction's risk, even if the existing session is active
- B. A longer remaining session lifetime so the change is not interrupted
- C. A copy of the session identifier displayed back to the customer
- D. Authorization based solely on the device having accessed the portfolio previously

Question 3 (CISSP4-081)

Scenario: A hospitality company learns that protected fingerprint templates used for workforce authentication may have been exposed. Unlike passwords, the underlying biometric characteristic cannot simply be changed by affected employees.

Which response is MOST appropriate?

- A. Continue accepting the same biometric alone because the stored values were templates rather than images
- B. Ask employees to reenroll the same fingerprint and treat it as a newly issued secret
- C. Lower the biometric match threshold so legitimate employees encounter fewer failures
- D. Revoke the affected enrollment, use an independent factor, and replace the compromised template protection before reenrollment

Question 4 (CISSP4-082)

Scenario: At a records facility, an employee enters a unique identifier, proves possession of a smart card with a personal identification number, and then requests entry to an archive room. The system checks the employee's assigned clearance before unlocking the door.

Which event represents authorization?

- A. The employee presents the unique identifier
- B. The system evaluates the assigned clearance before unlocking the archive

- C. The employee proves possession of the smart card
- D. The employee enters the personal identification number

Question 5 (CISSP4-083)

Scenario: Analysts in a shared operations room frequently leave authenticated workstations unattended for short periods. Authorized staff and escorted maintenance personnel may both be present in the room.

Which TWO controls would MOST directly reduce unauthorized use of unattended sessions?

Select 2 of the 5 options below.

- A. Require analysts to acknowledge a policy against leaving sessions unattended
- B. Automatically lock the workstation after a short period of inactivity and require reauthentication
- C. Expand video monitoring and review footage after suspected misuse
- D. Require analysts to change their passwords every thirty days
- E. Enforce escort and physical-access boundaries that keep maintenance personnel under authorized supervision

Question 6 (CISSP4-084)

Scenario: A benefits provider receives signed SAML assertions containing sensitive employment attributes. The signature lets the provider detect modification, but the security architect also wants only the intended provider to read the assertion contents if an intermediary captures them.

Which additional control BEST meets the confidentiality requirement?

- A. Increase the assertion validity period so decryption can be retried
- B. Add more attributes to make the signed assertion harder to reproduce
- C. Replace the identity provider's signature with an unsigned checksum
- D. Encrypt the assertion for the intended service provider in addition to signing it

Question 7 (CISSP4-085)

Scenario: A scheduled billing service must call an internal tax-calculation API. No employee is present during the transaction, and the billing service needs only a narrowly defined machine-to-machine permission.

Which authorization approach is MOST appropriate?

- A. Use an employee's interactive session and renew it whenever the job runs
- B. Authenticate the billing service as a confidential client and issue a scoped access token for its own identity
- C. Create a shared human username and store its password in the billing database
- D. Issue an identity token for a fictional employee and use it as API authorization

Question 8 (CISSP4-086)

Scenario: A collaboration portal accepts OpenID Connect sign-ins from several partner identity providers. It currently links users to local accounts by email address alone, even though two issuers could assert the same address or an address could later be reassigned.

Which account-correlation method BEST reduces the risk of linking the wrong identity?

- A. Use the validated combination of issuer and subject identifier as the federated identity key
- B. Use the displayed name because users can recognize it more easily
- C. Use email alone but ignore which identity provider issued the claim
- D. Create one local account for every email domain and share it among that partner's

users

Question 9 (CISSP4-087)

Scenario: A securities portal accepts federated identities from multiple corporate partners. Some partners authenticate users with strong multifactor methods, while others use passwords only. The portal requires higher assurance before allowing trade approval.

Which TWO controls BEST support the portal's requirement? Select 2 of the 5 options below.

- A. Accept assurance information only from validated, approved issuers and map it to the portal's defined requirement
- B. Assume every assertion has the same assurance because all partners have signed agreements
- C. Require step-up authentication when the federated session does not meet the trade-approval assurance level
- D. Allow each partner's assurance labels to pass through without an agreed interpretation
- E. Treat a recent authentication timestamp as proof that multifactor authentication was used

Question 10 (CISSP4-088)

Scenario: A shipping marketplace ends its business relationship with a regional broker. The broker's identity provider can still issue assertions, and previously federated broker users retain mapped local roles in the marketplace.

What should the marketplace do FIRST to end federated access reliably?

- A. Retain the trust until every broker user confirms that access is no longer needed
- B. Shorten the names of the broker's mapped roles while leaving assignments active
- C. Disable the broker issuer's trust, terminate active sessions, and remove or suspend associated local access
- D. Ask the broker to stop sending assertions without changing marketplace configuration

Question 11 (CISSP4-089)

Scenario: A customer-support organization has three specialist roles. All specialists need the permissions of a general support agent, and each specialist group also needs a small set of distinct functions. Administrators currently duplicate the general permissions in every role.

Which RBAC design BEST simplifies administration?

- A. Create a general role with common permissions and let specialist roles inherit it
- B. Give each specialist discretionary ownership of the support application
- C. Create one individual role for every employee and copy all permissions into it
- D. Replace job roles with a rule based only on the time of day

Question 12 (CISSP4-090)

Scenario: A clinical-research platform permits dataset access when a user's project-assignment attribute matches the dataset. Employees removed from projects sometimes retain access for days because the authorization service relies on a stale directory cache.

Which improvement MOST directly addresses the authorization weakness?

- A. Add more project roles while continuing to use the same stale attribute source
- B. Let users edit their own project-assignment attributes when work changes
- C. Treat a missing project attribute as permission to access all datasets

D. Obtain the attribute from an authoritative source with timely updates and fail securely when it is unavailable

Question 13 (CISSP4-091)

Scenario: An employee who created a classified engineering document wants to lower its label so a wider project team can read it. The organization uses mandatory access control, and document creators are not classification authorities.

How should the request be handled?

- A. Allow the creator to lower the label because ownership includes classification authority
- B. Require an authorized classification decision before changing the centrally enforced label
- C. Remove the label and rely on the creator's discretionary access list
- D. Permit the downgrade if every intended reader has authenticated successfully

Question 14 (CISSP4-092)

Scenario: A product manager owns several shared planning folders and controls their discretionary access lists. The manager leaves the company, but the folders remain active and must continue supporting the product team.

What is the BEST authorization action?

- A. Leave the departed manager as owner so existing permissions remain unchanged
- B. Make every current folder user a co-owner automatically
- C. Transfer ownership to an accountable successor and review the existing grants against current business need
- D. Remove all access controls because the original owner is no longer available

Question 15 (CISSP4-093)

Scenario: A financial-reporting application sends each access request to a remote policy decision point and receives an allow-or-deny response at its policy enforcement point. The architect is concerned about forged responses and interrupted communication.

Which TWO controls are MOST important for this design? Select 2 of the 5 options below.

- A. Retry an unreadable decision indefinitely while keeping the protected request open
- B. Authenticate and protect the integrity of decision traffic between the two components
- C. Record each returned decision without verifying which component produced it
- D. Define fail-secure behavior when a valid authorization decision cannot be obtained
- E. Cache approvals for the entire user session even when relevant policy or attributes change

Question 16 (CISSP4-094)

Scenario: A former employee returns to an airline after two years in a different job. The identity platform can reconnect the worker to the historical identity record, which still lists entitlements from the prior position.

Which approach is BEST for the rehire?

- A. Create an unrelated duplicate identity and discard the historical record
- B. Reactivate every former entitlement because it was previously approved
- C. Let the returning worker choose which legacy access to restore
- D. Reconnect the identity history but provision access from the current role and fresh approvals

Question 17 (CISSP4-095)

Scenario: New laboratory employees need access to a hazardous-materials ordering system only after completing required training and receiving supervisor approval. The current onboarding process grants the entitlement on the employee's first day regardless of training status.

Which provisioning change BEST enforces the requirement?

- A. Activate the entitlement only after authoritative training completion and supervisor approval are both recorded
- B. Grant access immediately and rely on users not to order materials before training
- C. Provide one trained employee's account to the entire new-hire group
- D. Assign the entitlement permanently to every laboratory job title

Question 18 (CISSP4-096)

Scenario: A departing data scientist used interactive credentials, personal API tokens, and a client certificate to access analytics services. The central directory account has been disabled, but some services validate the token or certificate without checking the directory on every request.

What additional action is MOST important?

- A. Keep the tokens active so completed analyses remain reproducible
- B. Change only the departed user's directory display name
- C. Inventory and revoke the user's active tokens, certificates, and downstream sessions
- D. Wait for each credential to expire even when immediate revocation is supported

Question 19 (CISSP4-097)

Scenario: A database engineer can request temporary production-administrator access and approve the same request using a second workflow role. The access is time-limited and fully logged, but no independent person confirms the business need.

Which change would MOST improve governance of the elevation?

- A. Extend the privilege duration so fewer requests require approval
- B. Require approval by an independent authorized party who cannot be the requester
- C. Keep self-approval but rename the approval role
- D. Replace individual elevation with one standing shared administrator account

Question 20 (CISSP4-098)

Scenario: After an acquisition, an organization inherits an application with hundreds of poorly described entitlements and no current business owner. The identity team is asked to launch an access review immediately, but reviewers cannot determine what the permissions allow or who may approve them.

What should occur FIRST?

- A. Retain all entitlements because ownership information is unavailable
- B. Ask each user to approve that user's own access
- C. Delete every entitlement before determining application dependencies
- D. Assign accountable application and entitlement owners, document access meaning, and then route review decisions

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-079) - Correct: C

Password spraying is distributed across many accounts, so controls should correlate activity broadly and apply proportionate delays, challenges, or blocking without creating an easy mass-lockout mechanism. Removing limits enables guessing, while one-failure permanent lockout creates a denial-of-service opportunity. More frequent expiration does not directly detect or throttle the active pattern.

Question 2 (CISSP4-080) - Correct: A

Fresh, risk-appropriate authentication before a sensitive change limits damage from an unattended or hijacked session. Extending the session increases exposure, and displaying an identifier does not prove the legitimate user is present. Prior device use may be a useful signal but is insufficient by itself for a high-impact destination change.

Question 3 (CISSP4-081) - Correct: D

Because an inherence characteristic has limited revocability, the organization should stop relying on the affected enrollment, require an independent factor, and correct the template-protection weakness before any controlled reenrollment. The fact that templates were exposed does not eliminate risk. Reenrolling the same characteristic without changing protection is not equivalent to issuing a new secret, and a lower threshold increases false acceptance risk.

Question 4 (CISSP4-082) - Correct: B

Authorization is the decision about whether the authenticated employee may enter the specific archive. The unique identifier supports identification, while the smart card and personal identification number contribute to authentication. Those steps establish identity confidence but do not themselves grant permission to the room.

Question 5 (CISSP4-083) - Correct: B, E

Automatic locking limits use of an unattended authenticated session, while enforced escort and physical boundaries reduce the opportunity for nonanalysts to approach workstations without supervision. Policy acknowledgment relies on behavior, video review is primarily detective, and routine password changes do not stop someone from using a session that is already authenticated.

Question 6 (CISSP4-084) - Correct: D

A digital signature protects integrity and source authenticity, while encryption for the service provider protects assertion confidentiality from intermediaries. A longer validity period increases exposure. Additional attributes do not provide secrecy, and an unsigned checksum does not establish trustworthy integrity or origin.

Question 7 (CISSP4-085) - Correct: B

A service acting on its own behalf should authenticate as a confidential client and receive an access token scoped to the required API operation. Reusing a human session or shared user credential creates improper dependency and weak attribution. An identity token describes authentication to a client and is not a substitute for an API access token.

Question 8 (CISSP4-086) - Correct: A

The subject identifier is defined within an issuer's namespace, so the validated issuer-and-subject pair provides the appropriate stable key for federated identity correlation. Display names and email addresses may change or collide. A domain-level shared account would also eliminate individual accountability.

Question 9 (CISSP4-087) - Correct: A, C

The portal must trust assurance claims only from approved issuers and map them to its own access requirement; when the achieved assurance is insufficient, step-up authentication closes the gap. A contract alone does not make all authentication methods equivalent. Unmapped partner labels can carry inconsistent meanings, and authentication time does not establish which factors were used.

Question 10 (CISSP4-088) - Correct: C

Ending the technical trust prevents new assertions from being accepted, while session termination and local-access removal address access already established at the relying service. Waiting for users or merely renaming roles leaves access active. A request to the former partner is not an enforcement control within the marketplace.

Question 11 (CISSP4-089) - Correct: A

A role hierarchy centralizes common permissions in the general role and lets specialist roles add only their distinct needs, reducing duplication and inconsistent updates. Resource ownership is not a substitute for job-based authorization. Per-user roles increase administration, and a time rule cannot represent the required job functions.

Question 12 (CISSP4-090) - Correct: D

ABAC decisions are only as reliable as the attributes they evaluate. Timely authoritative updates and secure handling of unavailable attributes prevent removed users from retaining access through stale data. More roles do not correct the source, self-editing undermines trust, and permissive treatment of missing attributes fails open.

Question 13 (CISSP4-091) - Correct: B

Under mandatory access control, security labels and permitted changes are governed by central policy and designated authority, not by the resource creator's discretion. An access list cannot replace the classification decision, and successful authentication does not establish authorization to receive downgraded information.

Question 14 (CISSP4-092) - Correct: C

Discretionary resources still require an active, accountable owner. Transferring ownership and reviewing grants preserves business continuity while removing stale or unjustified access. Retaining a departed owner leaves no responsible decision-maker, and automatic co-ownership broadens authority. Removing controls exposes the folders indiscriminately.

Question 15 (CISSP4-093) - Correct: B, D

Protected, authenticated decision traffic prevents an attacker from forging or altering authorization results, while fail-secure behavior defines a safe outcome when no valid decision is available. Indefinite retry leaves the request unresolved, and logging an unverified result does not make it trustworthy. Unconditional session-long caching can preserve access after a relevant policy or attribute change.

Question 16 (CISSP4-094) - Correct: D

Linking the returning worker to the historical identity preserves attribution and record continuity, while current-role provisioning prevents stale access from being restored automatically. A duplicate identity fragments history. Previous approvals may no longer reflect business need, and the worker is not the accountable approver for legacy entitlements.

Question 17 (CISSP4-095) - Correct: A

Provisioning should evaluate the verified prerequisites and activate access only when both are satisfied. User promises do not enforce the condition, and account sharing eliminates individual accountability. Permanent birthright access based only on job title ignores the required training and explicit approval.

Question 18 (CISSP4-096) - Correct: C

Deprovisioning must address every credential and session that can continue operating independently of the disabled directory account. Revoking personal tokens, certificates, and downstream sessions closes those alternate paths. Historical reproducibility does not require active credentials, a display-name change has no revocation effect, and waiting unnecessarily extends exposure.

Question 19 (CISSP4-097) - Correct: B

Independent approval provides separation of duties and verifies the stated need before privileged access is granted. Time limits and logging remain valuable but do not compensate for self-authorization. Longer elevation increases exposure, renaming the role changes nothing, and a shared administrator account weakens least privilege and accountability.

Question 20 (CISSP4-098) - Correct: D

A meaningful review requires accountable owners and understandable entitlement information so reviewers can evaluate business need and risk. Default retention preserves potentially excessive access, while self-approval lacks independence. Deleting everything without understanding dependencies can disrupt essential operations and is not an informed access decision.